Stoquify Platform Hardening Master Plan — 2026-07-28

Program verdict

The remediation program is active but not complete. The current dirty workspace contains strong domain foundations and extensive uncommitted work. This run applies only independently safe containment slices and produces the complete dependency-ordered program. Structural database, provider, statutory and production-release changes remain gated until migration, external evidence and rollback prerequisites exist.

Baseline

Authoritative inputs are the 2026-07-28 workflow audit, 22-family registry, source-of-truth map, 20-finding inconsistency register and prior readiness artifacts. Revalidation confirmed the high-risk conditions remain present at program entry. The supplied attachment ends inside the verification command block; execution therefore also follows the complete hardening specification established in the immediately preceding task context.

Governance

- Lead owner: program orchestrator.
- One active slice per shared contract.
- Findings close only as verified remediated, partially remediated, blocked external, deferred with accepted risk, or superseded by approved decision.
- Implementation presence is not completion.
- No destructive Prisma command, production mutation, secret rotation, provider mutation or deployment is authorized.

Phases and gates

Phase 0 — containment

Scope: reject unauthoritative store credit; deny generic PO approval; remove request-derived trusted origins; preserve statutory/export blockers. Exit requires focused denial tests and no regression of supported paths.

Phase 1 — trust boundaries

Scope: formally decide ADR-0002; implement scoped client/RLS/repository boundary; prohibit raw client; mandatory entitlement on external mutations; transactional audit outbox; token digests/CAS redemption; offline original actor and narrow replay authority. Entry is blocked until the database-boundary design, migration strategy and rollback proof are approved.

Phase 2 — financial truth

Scope: immutable store-credit ledger; provider-authoritative tender/refund lifecycle; CAS/atomic customer and drawer balances; inventory replay idempotency; AP exception uniqueness; Payment-to-PaymentTransaction

transition. Entry requires Phase 1 tenant/authorization gates and approved schema compatibility plan.

Phase 3 — projection convergence

Scope: shared cash/AR/refund/settlement semantic catalog; golden fixtures; shared adapters; freshness/provenance; duplicate facade retirement; role-aware accessible recovery. Entry requires approved financial truth contracts.

Phase 4 — assurance and release

Scope: expanded workflow assurance, migration history, managed secrets, production observability, webhook/provider authenticity, statutory provenance, backup/restore/rollback drills and clean-commit evidence. External and human approval remain mandatory.

Workstream ownership

1. Tenant/access: DB scoping, raw-client gate, RBAC/entitlement matrix.
2. Identity/security: origins, audit outbox, invite token digest, redaction.
3. Purchasing: canonical PO approval, AP idempotency and settlement vocabulary.
4. POS/payment: store credit, provider states, refunds, concurrency.
5. Inventory: event ordering, valuation, correction and atomic production.
6. Accounting/reconciliation: payment transition, semantic contract, close truth.
7. HRIS/payroll/compliance: provenance, correction, provider/statutory evidence.
8. Read models/UI: shared projections, recovery, accessibility and route convergence.
9. Reliability/release: telemetry, migrations, secrets, runbooks and gates.

Phase 0 implementation selected in this run

- Trusted-origin fail-closed normalization and spoofing tests.
- Generic PO bulk-approval denial and tests.
- Store-credit fail-closed denial before transactional side effects and tests.

These slices require no migration and do not invent provider or statutory facts.

Program acceptance

All 20 findings require an evidence-backed terminal status; all P0/P1 defects require verified remediation or explicit external blocking; projection totals must converge; release blockers must close against an approved target; rollback must preserve append-only financial/audit history; independent reviewers retain final authority.